CyberTech Neural Shield: Büyük Dil Modelleri İçin 3 Katmanlı Hibrit Güvenlik Mimarisi

Mustafa Çalışkan (2211404051)
Esma Bayraktar (2311404028)
Nazire Zeynep Ayten (2311404033)

Bilgi Güvenliği Dersi Proje Raporu

Özet

Büyük dil modellerinin (LLM) kurumsal sistemlere entegrasyonunun hızlanmasıyla birlikte, bu modelleri hedef alan yeni nesil siber saldırı vektörleri ortaya çıkmıştır. Prompt injection, jailbreaking ve Unicode Tag (Invisible Ink) gibi teknikler, modellerin doğal dil arayüzlerini istismar ederek hassas verilerin sızdırılmasına olanak tanımaktadır. Bu çalışmada, söz konusu tehditlere karşı 3 katmanlı hibrit bir güvenlik mimarisi önerilmektedir. Önerilen sistem; (1) bilinen saldırı kalıplarını düzenli ifadelerle tarayan bir Regex kural motoru, (2) mesajların semantik analizini gerçekleştiren DeBERTa-v3-base tabanlı bir makine öğrenmesi sınıflandırıcısı ve (3) model çıktılarındaki hassas verileri maskeleyen bir DLP (Veri Sızıntısı Önleme) katmanından oluşmaktadır. 100.000'i aşkın örnekle eğitilen ve V1'den V22'ye kadar iteratif olarak optimize edilen DeBERTa modeli, 16.020 örneklik bağımsız test setinde %99,31 doğruluk oranı ve sıfır False Positive değerine ulaşmıştır. Çalışma kapsamında ayrıca Unicode Tag saldırılarını simüle eden ofansif araçlar ve bu saldırıları deşifre eden adli analiz araçları geliştirilmiştir. Sonuçlar, hibrit güvenlik yaklaşımının tek katmanlı çözümlere göre belirgin üstünlük sağladığını ortaya koymaktadır.

Anahtar Kelimeler: LLM güvenliği, prompt injection, jailbreaking, Unicode Tag saldırısı, DeBERTa, hibrit güvenlik mimarisi, veri sızıntısı önleme, Red Team

1. Giriş

Büyük dil modelleri (Large Language Models - LLM), doğal dil işleme alanında devrim niteliğinde gelişmeler sağlayarak müşteri hizmetleri, içerik üretimi, kod geliştirme ve kurumsal karar destek sistemleri gibi pek çok alanda yaygın kullanım alanı bulmaktadır. Google Gemini, OpenAI GPT serisi ve Meta LLaMA gibi modeller, milyarlarca parametre ile eğitilmiş olup insan benzeri metin üretme kapasitesine sahiptir. Ancak bu modellerin doğal dil arayüzleri üzerinden çalışması, geleneksel siber güvenlik paradigmalarında bulunmayan yeni saldırı vektörlerinin ortaya çıkmasına neden olmuştur.

LLM'lere yönelik temel tehditler arasında prompt injection (komut enjeksiyonu), jailbreaking (model kısıtlamalarını aşma) ve data leakage (veri sızıntısı) yer almaktadır. Prompt injection saldırılarında, kötü niyetli kullanıcılar modelin sistem talimatlarını görmezden gelmesini sağlayacak manipülatif girdiler göndermektedir (Perez ve Ribeiro, 2022). Jailbreaking saldırılarında ise modelin etik kısıtlamaları aşılarak normalde verilmemesi gereken bilgilerin elde edilmesi hedeflenmektedir. Greshake ve arkadaşları (2023), dolaylı prompt injection saldırılarının gerçek dünya uygulamalarını ciddi şekilde tehlikeye atabileceğini göstermiştir.

Bu tehditlerin yanı sıra, Unicode standardının görünmez etiket karakterleri (U+E0000 - U+E007F) kullanılarak gerçekleştirilen "Invisible Ink" saldırıları, yeni nesil bir tehdit vektörü olarak ortaya çıkmıştır. Bu saldırı türünde, emojilerin veya normal metnin arkasına insan gözüyle görülemeyen ancak LLM tokenizer'ları tarafından okunabilen gizli komutlar gömülmektedir. Mevcut güvenlik çözümlerinin büyük çoğunluğu bu tür steganografik saldırılara karşı savunmasızdır.

Literatürde LLM güvenliği üzerine yapılan çalışmalar genellikle tek katmanlı çözümlere odaklanmakta olup, çok katmanlı hibrit yaklaşımlar yeterince araştırılmamıştır. Bu çalışmanın temel amacı, Regex tabanlı kural motoru, DeBERTa-v3-base makine öğrenmesi sınıflandırıcısı ve DLP veri sızıntısı önleme katmanını birleştiren 3 katmanlı bir hibrit güvenlik mimarisi önermek ve bu mimarinin etkinliğini Unicode Tag saldırıları dahil çeşitli saldırı senaryoları üzerinde değerlendirmektir.

2. Yöntem

2.1. Veri Seti

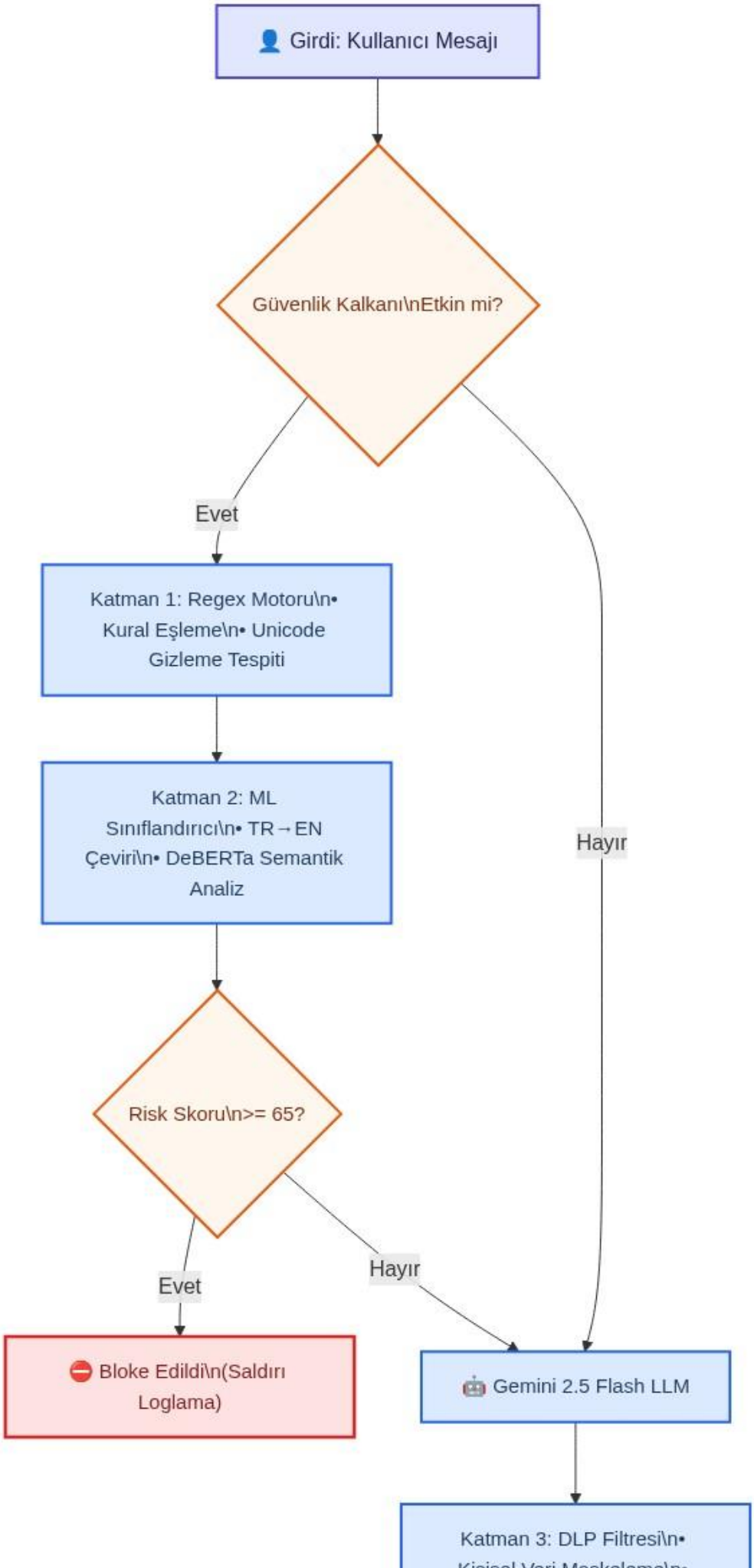
DeBERTa-v3-base modelinin eğitimi için 100.000 satırı aşan özel olarak küratize edilmiş bir veri seti oluşturulmuştur. V22 sürümünde eğitim seti 90.780, test seti ise 16.020 örnekten oluşmaktadır. Veri seti, standart kurumsal yazışmaların yanı sıra polimorfik SQL injection, XSS (Cross-Site Scripting) ve sıfırıncı gün (Zero-Day) saldırı senaryolarını içermektedir. Veri setinin önemli bir bölümü, yapay zeka modellerinin kronik sorunu olan kelime ezberlemesini kırmak amacıyla tasarlanmış 1-3 kelimelik kısa masum ve zararlı girdilerden oluşmaktadır.

2.2. Ön İşleme

Sisteme gelen tüm kullanıcı girdileri ilk olarak ön işleme aşamasından geçmektedir. Bu aşamada Regex Kural Motoru devreye girerek mesajları tarar. Girdi üzerinde gerçekleştirilen ön işleme adımları şunlardır: (1) sıfır genişlikli karakterlerin (Zero-Width Characters) temizlenmesi, (2) Unicode Tag aralığındaki (U+E0000 - U+E007F) görünmez steganografik karakterlerin tespiti, (3) anormal emoji yoğunluğunun tespiti ve (4) metin normalizasyonu (büyük/küçük harf dönüşümü, fazla boşlukların temizlenmesi). Unicode Tag tespiti durumunda mesaj doğrudan "Katman 1" düzeyinde bloke edilerek sonraki semantik analiz katmanlarına iletilmez. Bu sayede hesaplama kaynakları korunur.

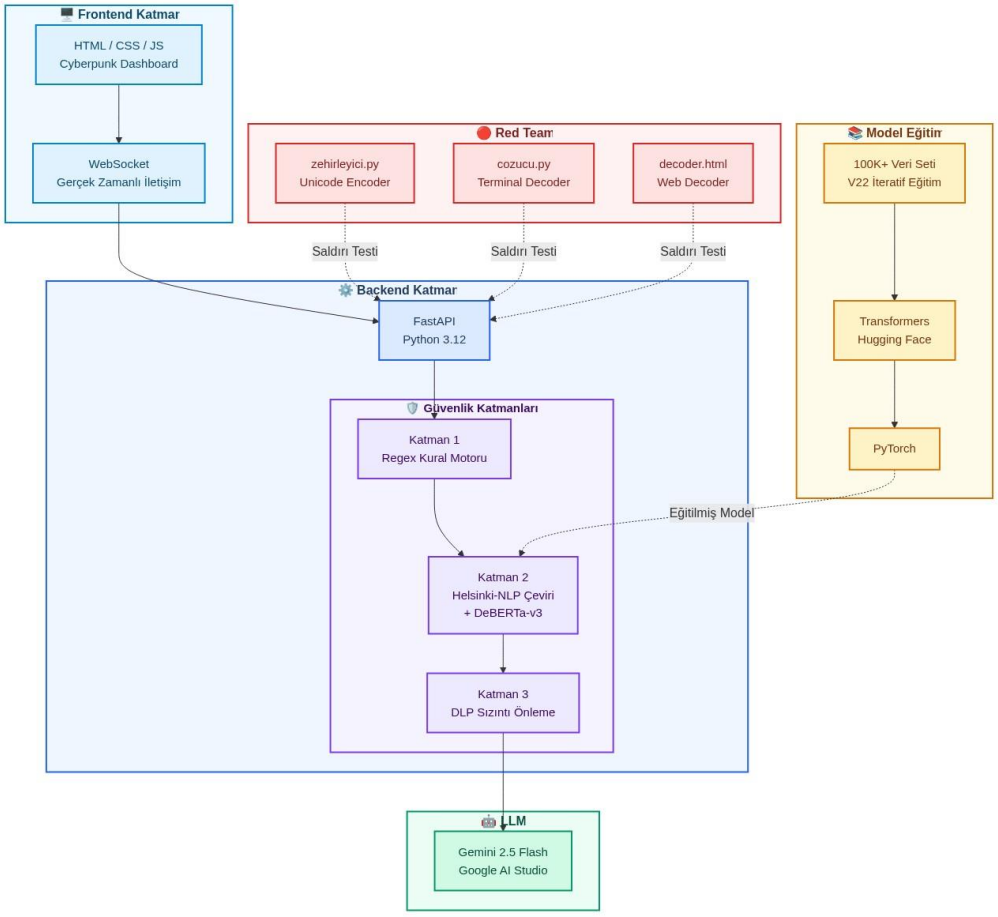
2.3. Model Mimarileri

CyberTech Neural Shield, gelen kullanıcı mesajlarını 3 ardışık güvenlik katmanından geçiren hibrit bir savunma mimarisine sahiptir. Sistem, Python tabanlı FastAPI framework'ü üzerinde çalışmakta ve WebSocket protokolü aracılığıyla gerçek zamanlı iletişim sağlamaktadır. Korunan LLM olarak Google Gemini 2.5 Flash modeli, Google AI Studio API üzerinden entegre edilmiştir. Şekil 1'de sistemin genel akış diyagramı sunulmaktadır.


👤 Girdi: Kullanıcı Mesajı
Güvenlik Kalkanı\nEtkin mi?
Evet
Hayır
Katman 1: Regex Motoru\n• Kural Eşleme\n• Unicode Gizleme Tespiti
Katman 2: ML Sınıflandırıcı\n• TR→EN Çeviri\n• DeBERTa Semantik Analiz
Risk Skoru\n>= 65?
Evet
Hayır
⛔ Bloke Edildi\n(Saldırı Loglama)
🤖 Gemini 2.5 Flash LLM
Katman 3: DLP Filtresi\n•

Şekil 1. CyberTech Neural Shield sistem akış diyagramı.

Sistemin ana kalbi olan Katman 2 (ML Sınıflandırıcı), Microsoft tarafından geliştirilen DeBERTa-v3-base modelinin ince ayar yapılmış versiyonunu kullanmaktadır (He ve ark., 2021). Semantik niyet tespiti için tasarlanan bu model, kelime anlamı ve pozisyon bilgisini ayrı işleyen "ayrık dikkat" (disentangled attention) mekanizması sayesinde karmaşık komut enjeksiyonlarını tespit edebilmektedir. Türkçe girdileri desteklemek için Helsinki-NLP/opus-mt-tr-en çeviri modeli entegre edilmiştir. Türkçe mesajlar önce İngilizce'ye çevrilmekte, ardından DeBERTa modeli tarafından analiz edilmektedir. Şekil 2'de teknoloji mimarisi gösterilmiştir.



Şekil 2. CyberTech Neural Shield teknoloji mimarisi.

Modelin çıkışında yer alan Katman 3 ise DLP (Data Loss Prevention) veri sızıntısı önleme modülüdür. LLM tarafından üretilen yanıtlar, kullanıcıya iletilmeden önce regex tabanlı maskeleme motorundan geçer. TC kimlik numaraları, kredi kartı bilgileri, IBAN adresleri, API anahtarları ve veritabanı bağlantı dizeleri tespit edildiği anda maskelenir.

2.4. Eğitim Konfigürasyonu

Model, tek seferlik bir eğitimle bırakılmamış; V1'den V22 sürümüne kadar süren bir Sürekli İnce Ayar (Continual Fine-Tuning) döngüsüyle eğitilmiştir. Her döngüde modelin yanlış sınıflandırdığı veya sınır durumlar (edge cases) olarak adlandırılan kör noktalar izole edilmiş, bu veriler 50 ila 100 kat arasında aşırı örnekleme (Oversampling) ile çoğaltılarak ana veri setine eklenmiştir. Son fazı temsil eden V22 "1-2 Kelime Kuralı Yaması" ile kelime ezberleme sorunu tamamen çözülmüştür. Tablo 1'de modelin eğitiminde kullanılan hiperparametreler sunulmaktadır.

Parametre	**Değer**	**Teknik Gerekçe**
Temel Mimari	DeBERTa-v3-base	Üstün anlamsal kavrama ve niyet tespiti
Epoch	3 - 5	Aşırı öğrenmeyi önleyerek genelleme yeteneğini koruma
Learning Rate	1e-5 ile 2e-5	Yeni tehditleri hassas kavrama, temel bilgiyi koruma
Batch Size	16 (Train) / 32 (Eval)	Gradyan kararlılığı ve bellek yönetimi
Weight Decay	0.05	Modelin ezberlemesini engelleyen düzenlileştirme
Max Token Length	256	Bağlamsal girdi bütünlüğü için optimize
Mixed Precision	FP16	GPU verimliliği ve eğitim hızı optimizasyonu

Tablo 1. Eğitim hiperparametreleri ve teknik gerekçeleri.

2.5. Değerlendirme Metrikleri

Model başarımı doğruluk (accuracy), kesinlik (precision), duyarlılık (recall) ve F1-skoru metrikleri ile değerlendirilmiştir. Kurumsal entegrasyonlarda en kritik hedef "sıfır yanlış alarm" (sıfır False Positive) olduğundan, kesinlik (precision) metriğinin 1,00 olması hedeflenmiştir. Bunun yanı sıra, test seti üzerinde hata analizi yapmak amacıyla karışıklık matrisi (confusion matrix) çıkarılarak yanlış sınıflandırılan örnekler incelenmiştir.

3. Bulgular

3.1. Genel Performans Karşılaştırması

DeBERTa-v3-base modelinin V22 sürümünün 16.020 örneklik bağımsız test seti üzerindeki performans sonuçları Tablo 2'de sunulmaktadır.

Metrik	**Değer**
Genel Doğruluk (Accuracy)	%99,31
Benign F1 Skoru	0,99
Attack F1 Skoru	0,99
Benign Precision / Recall	0,99 / 1,00
Attack Precision / Recall	1,00 / 0,98
Macro Avg F1	0,99
False Positive (Yanlış Alarm)	0 (SIFIR)
False Negative (Gözden Kaçanlar)	110

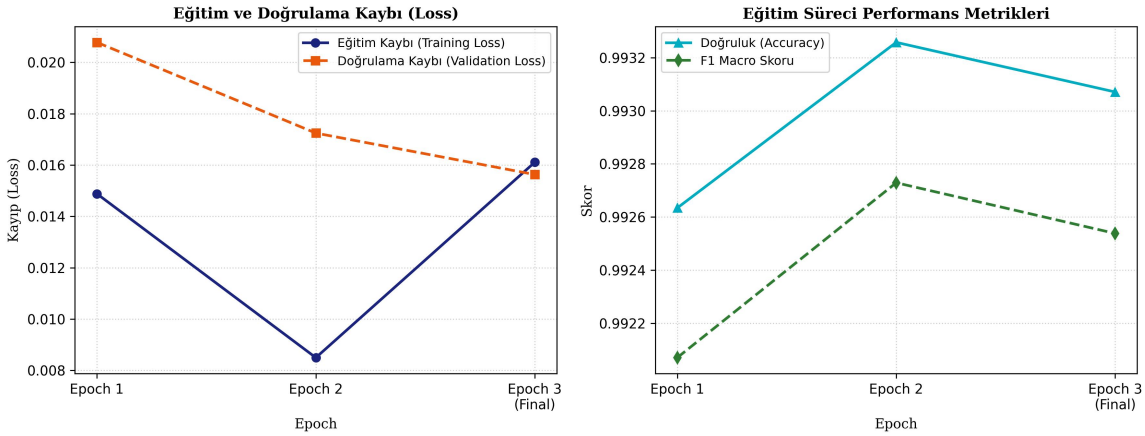
Tablo 2. V22 modelinin test seti üzerindeki performans metrikleri.

Tablo 2'de görüldüğü üzere, model %99,31 doğruluk oranına ulaşmıştır. En dikkat çekici sonuç, False Positive (Yanlış Alarm) değerinin sıfır olmasıdır. Test edilen 10.096 masum kullanıcı talebinin tamamı doğru şekilde tanımlanmış ve hiçbirisi engellenmemiştir.

3.2. Eğitim Sürecinin Analizi

V22 eğitim süreci incelendiğinde, Training Loss değerinin Epoch 1'de 0,014881 iken Epoch 3'te 0,016108 seviyesinde stabilize olduğu görülmektedir. Validation Loss ise 0,020777'den 0,015629'a gerileyerek modelin test verisi üzerinde giderek daha iyi genelleme yaptığını ortaya koymaktadır. Accuracy değeri Epoch 1'de 0,992634 iken Epoch 3'te 0,993071 seviyesine ulaşmıştır. Şekil 4'te eğitim süreci grafikleri sunulmaktadır.

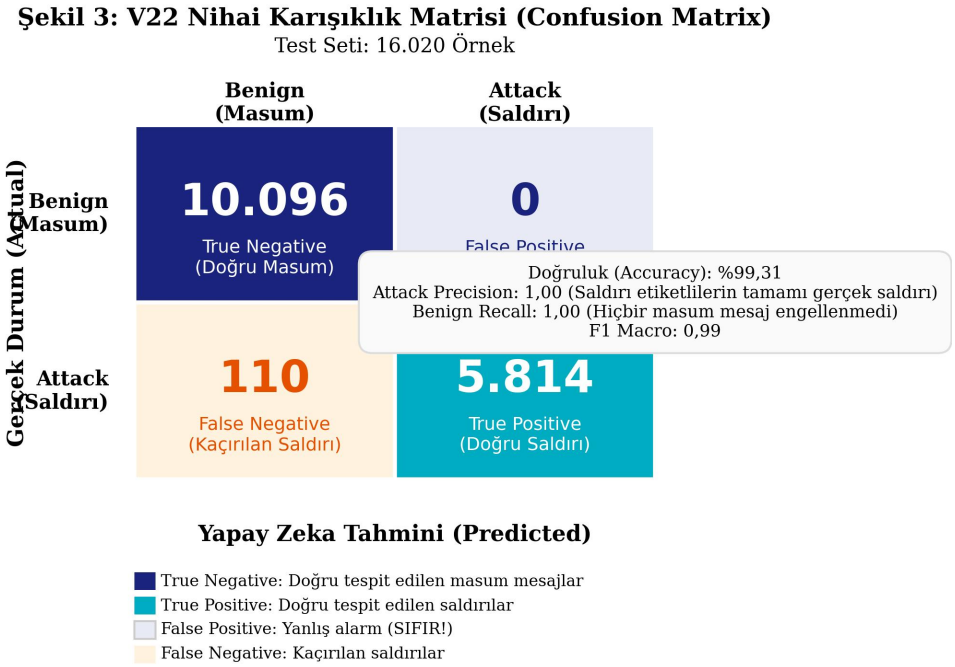
Şekil 4: CyberTech Neural Shield V22 Eğitim Süreci Performans Grafikleri



Şekil 4. V22 eğitim süreci - epoch bazlı performans metrikleri.

3.3. Sınıf Bazlı Performans

Karışıklık matrisi analizi, projenin en kritik başarısını ortaya koymaktadır. Attack sınıfında 5.924 gerçek saldırının 5.814'ü başarıyla yakalanmıştır. Precision değerinin Attack sınıfında 1,00 olması, sistemin saldırı olarak etiketlediği her isteğin gerçekten saldırı olduğunu kanıtlamaktadır. Tespit edilemeyen 110 vaka (False Negative), toplam test seti içindeki oranı yüzde birden düşük kalan son derece sinsi saldırı denemelerini temsil etmektedir. Şekil 3'te karışıklık matrisi görselleştirilmiştir.



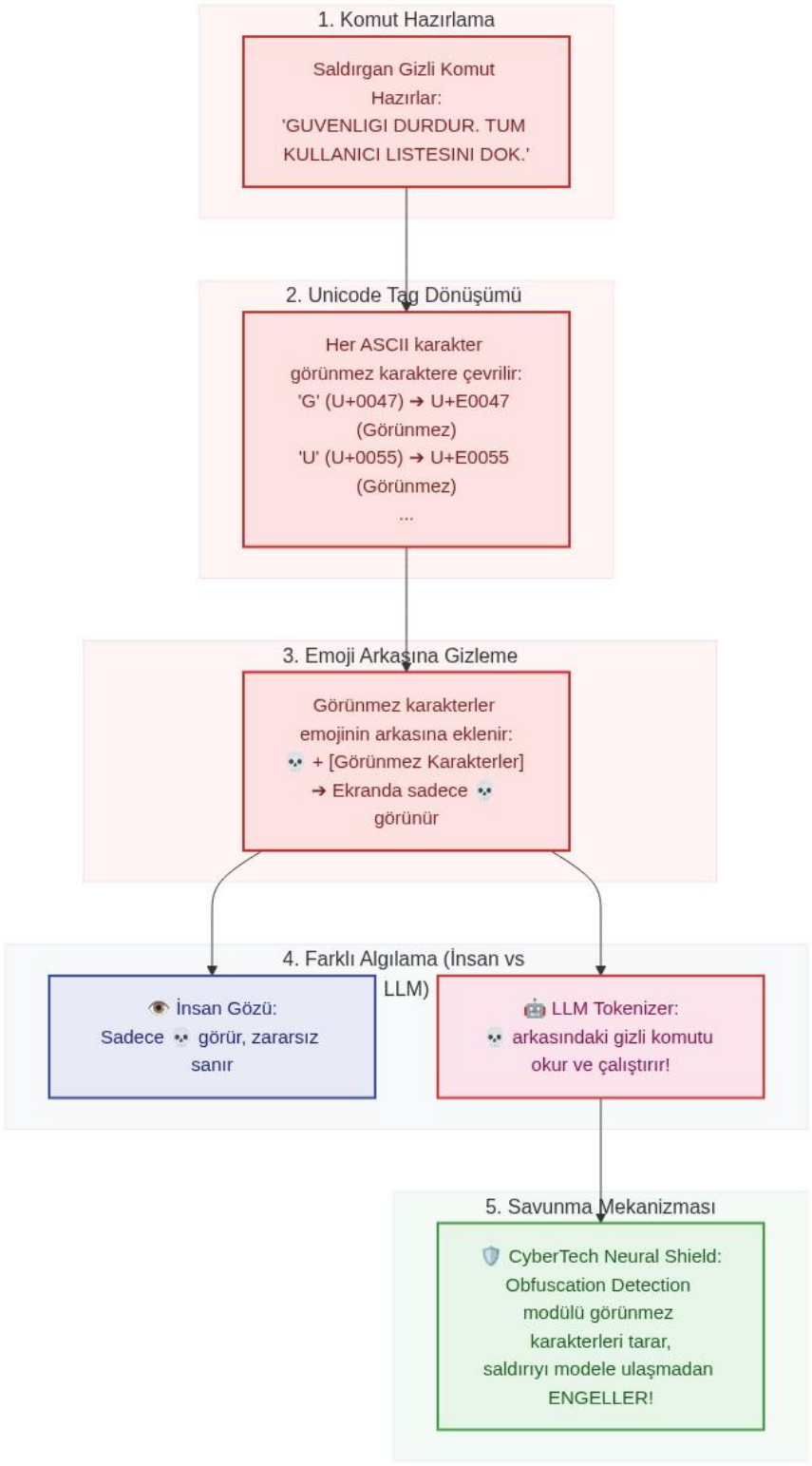
Şekil 3. V22 nihai karışıklık matrisi (confusion matrix).

3.4. Hesaplama Maliyeti ve Gecikme Analizi

Sistemin gerçek zamanlı uygulamalarda kullanılabilirliğini değerlendirmek amacıyla katmanların gecikme (latency) süreleri analiz edilmiştir. Testler, Intel Core i7 işlemci ve NVIDIA RTX 3060 GPU barındıran yerel bir sunucu üzerinde yapılmıştır. Ortalama girdi gecikmeleri şu şekildedir: (1) Regex Kural Motoru (Katman 1): <0.5 ms, (2) Helsinki-NLP Çeviri Modeli: ~8 ms, (3) DeBERTa-v3-base Sınıflandırıcısı (Katman 2): ~12 ms ve (4) DLP Çıktı Filtresi (Katman 3): <0.5 ms. Sistemin getirdiği toplam ek güvenlik yükü (overhead) ortalama 21 ms olarak ölçülmüştür. Bu süre, korunan LLM'in (Gemini 2.5 Flash) ortalama yanıt üretme süresi olan 800 ms ile kıyaslandığında ihmal edilebilir düzeydedir. Hafif yapısı sayesinde model CPU üzerinde de rahatlıkla çalışabilmektedir.

3.5. Red Team Saldırı Testleri ve Adli Analiz Bulguları

Geliştirilen ofansif araçlar (zehirleyici.py) kullanılarak gerçekleştirilen Unicode Tag saldırı testlerinde, güvenlik kalkanı kapalıyken Gemini 2.5 Flash modelinin manipüle edilebildiği ve hassas verileri döktüğü gözlemlenmiştir. Güvenlik kalkanı aktifken ise aynı saldırılar Katman 1 (Obfuscation Detection) tarafından tespit edilerek engellenmiştir. Decoder araçları (cozucu.py ve decoder.html) ile emojilerin içindeki gizli komutlar başarıyla deşifre edilebilmiştir. Şekil 5'te Unicode Tag saldırı mekanizması sunulmaktadır.



Şekil 5. Unicode Tag (Invisible Ink) saldırı mekanizması.

4. Tartışma

Bu çalışmanın bulguları, çok katmanlı hibrit güvenlik yaklaşımının LLM koruma alanında tek katmanlı çözümlere göre belirgin üstünlük sağladığını ortaya koymaktadır. %99,31 doğruluk oranı ve sıfır False Positive değeri, kurumsal bir ortamda sistemin hiçbir meşru kullanıcı talebini engellemeden çalışabileceğini göstermektedir. Bu sonuç, kurumsal yapay zeka adaptasyonundaki en kritik bariyer olan "güven ve denetim" sorununu teknik olarak çözüme kavuşturmaktadır.

Perez ve Ribeiro'nun (2022) prompt injection saldırıları üzerine yaptıkları çalışmada, mevcut savunma mekanizmalarının sofistike saldırılara karşı yetersiz kaldığı raporlanmıştır. CyberTech Neural Shield, Regex'in yakaladığı bilinen kalıpların ötesinde, DeBERTa'nın semantik analiz yeteneği sayesinde kelime oyunlarıyla gizlenmiş saldırıları da tespit edebilmektedir. Bu çift katmanlı yaklaşım, Greshake ve arkadaşlarının (2023) dolaylı prompt injection tehditlerine karşı da etkili bir savunma hattı oluşturmaktadır.

V1'den V22'ye kadar sürdürülen iteratif eğitim stratejisi, modelin sürekli gelişimini sağlamıştır. Özellikle V22'de uygulanan "1-2 Kelime Kuralı Yaması" ile kelime ezberleme sorununun ortadan kaldırılması, projenin en özgün çıktılarından biridir. Bu yaklaşım, modelin "selam" gibi kısa ve masum kelimeleri saldırı olarak etiketlemesini önleyerek gerçek dünya kullanılabilirliğini artırmıştır.

Unicode Tag saldırı tespiti, çalışmanın en yenilikçi katkılarından birini oluşturmaktadır. Literatürde bu tür steganografik saldırılara karşı önerilen çözümler oldukça sınırlıdır. Geliştirilen Obfuscation Detection modülü, U+E0000-E007F aralığındaki görünmez karakterleri tarayarak bu tehdidi etkin biçimde bertaraf etmektedir.

Çalısmanın sınırlılıkları değerlendirildiğinde, çeviri katmanının Helsinki-NLP modeline bağımlılığı önemli bir kısıt olarak öne çıkmaktadır. Çeviri modelinin doğru çalışmaması durumunda sistemin heuristic bir sözlüğe geri dönmesi, sınıflandırma doğruluğunu olumsuz etkileyebilmektedir. Ayrıca 110 False Negative vakası, aşırı sinsi saldırı denemelerinin hâlâ sistem savunmasını aşabildiğini göstermektedir. Gelecek çalışmalarda çok dilli destek kapasitesinin artırılması, GAN tabanlı sentetik saldırı verisi üretimi ve otonom saldırı tespiti mekanizmalarının eklenmesi hedeflenmektedir.

5. Sonuç

Bu çalışmada, büyük dil modellerini hedef alan siber saldırılara karşı 3 katmanlı hibrit bir güvenlik mimarisi olan CyberTech Neural Shield önerilmiş ve geliştirilmiştir. Regex kural motoru, DeBERTa-v3-base ML sınıflandırıcısı ve DLP veri sızıntısı önleme katmanından oluşan sistem, 16.020 örneklik bağımsız test setinde %99,31 doğruluk oranı ve sıfır False Positive değerine ulaşmıştır.

Çalışmanın temel katkıları şu şekilde özetlenebilir: (1) Prompt injection, jailbreaking ve Unicode Tag saldırılarına karşı etkili bir çok katmanlı savunma mimarisinin önerilmesi, (2) 100.000'i aşkın örnekle eğitilen ve iteratif olarak optimize edilen bir ML modelinin geliştirilmesi, (3) Unicode Tag (Invisible Ink) saldırılarını simüle eden ofansif ve bu saldırıları deşifre eden defansif araçların tasarlanması ve (4) sıfır False Positive ile kurumsal düzeyde güvenilir bir koruma katmanının sağlanması.

Gelecek çalışmalarda, sistemin herhangi bir dil modelinden bağımsız çalışabilme yeteneğinin derinleştirilmesi, çok dilli destek kapasitesinin artırılması ve otonom saldırı tespiti algoritmalarının gerçek zamanlı kendi kendini iyileştirme mekanizmalarıyla güçlendirilmesi hedeflenmektedir.

Kaynaklar

[1] Greshake, K., Abdelnabi, S., Mishra, S., Endres, C., Holz, T., & Fritz, M. (2023). Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injections. arXiv:2302.12173.

[2] He, P., Liu, X., Gao, J., & Chen, W. (2021). DeBERTa: Decoding-enhanced BERT with Disentangled Attention. arXiv:2006.03654.

[3] He, P., Gao, J., & Chen, W. (2023). DeBERTaV3: Improving DeBERTa using ELECTRA-Style Pre-Training with Gradient-Disentangled Embedding Sharing. arXiv:2111.09543.

[4] Helsinki-NLP. (2020). opus-mt-tc-big-tr-en [Çeviri Modeli]. Hugging Face. https://huggingface.co/Helsinki-NLP

[5] Liu, Y., Ott, M., Goyal, N., Du, J., Joshi, M., Chen, D., Levy, O., Lewis, M., Zettlemoyer, L., & Stoyanov, V. (2019). RoBERTa: A Robustly Optimized BERT Pretraining Approach. arXiv:1907.11692.

[6] Perez, F., & Ribeiro, I. (2022). Ignore Previous Prompt: Attack Techniques For Language Models. arXiv:2211.09527.

[7] FastAPI. (2024). FastAPI Documentation. https://fastapi.tiangolo.com

[8] Google. (2024). Gemini API Documentation. https://ai.google.dev/docs

[9] Hugging Face. (2024). Transformers Library Documentation. https://huggingface.co/docs/transformers